

UNIVERSIDADE DE MOGI DAS CRUZES
BACHARELADO EM ENGENHARIA DE SOFTWARE

Avraham Ben Aram de Souza
Edson Miguel Junior
Enrico de Andrade Bertozzi Miranda
Miguel Santana da Costa

ECHOES
Sistema de Simulação De Ausculta Cardíaca E Pulmonar Usando IoT

Orientador: Prof. Dr. Fabiano Bezerra Menegidio

Mogi das Cruzes – SP
2026

SUMÁRIO

1 PLANEJAMENTO	3
1.1 Introdução	3
1.2 Escopo	3
1.3 Objetivo Geral	4
1.4 Objetivos Específicos	4
1.5 Partes Interessadas	4
1.6 Estrutura Analítica do Projeto (EAP)	5
2 FLUXO DE CADASTRO	7
2.1 Administradores	7
2.2 Professores	7
2.3 Alunos	7
3 REQUISITOS	9
3.1 Servidor	9
3.1.1 Requisitos Funcionais	9
3.1.2 Requisitos de Dados	11
3.1.3 Requisitos Não Funcionais	11
3.1.4 Regras de Negócio	12
4 SEGURANÇA DA API	13
4.1 Armazenamento Seguro de Senha	13
4.2 Proteção contra ataques de Brute Force	14
4.3 Autenticação via Token	15
4.4 Autenticação Multifator (MFA)	16
4.5 Redefinição e Alteração de Senha	16
4.6 Logs de Auditoria	17
4.7 Criptografia de Token	17
4.8 Criptografia e Comunicação Segura	18

1 PLANEJAMENTO

1.1 Introdução

O uso de animais em atividades práticas nos cursos superiores de Medicina Veterinária é amplamente debatido no meio acadêmico em razão das implicações éticas, pedagógicas e científicas. Esse debate ganhou maior relevância nas últimas décadas com o fortalecimento das discussões sobre bem-estar animal, bioética e métodos alternativos de ensino.

No contexto brasileiro, a Lei nº 11.794, de 2008, regulamenta o uso de animais no ensino e em pesquisas acadêmicas, além de criar o Conselho Nacional de Controle de Experimentação Animal (CONCEA). O CONCEA normatiza, supervisiona e acompanha as práticas com animais, criando normas para uso humanitário, credenciando instituições e incentivando métodos alternativos capazes de reduzir, refinar ou substituir o uso de animais vivos.

Entre suas atividades, destacam-se a criação de normas para o uso humanitário de animais, o credenciamento de instituições que desenvolvem atividades de ensino ou pesquisa com animais e o incentivo à adoção de métodos alternativos capazes de reduzir, refinar ou substituir o uso de animais vivos.

Simuladores didáticos são eficazes no treinamento de habilidades clínicas, reduzindo ansiedade e permitindo repetição ilimitada das técnicas. Entretanto, muitos apresentam elevado custo e complexidade tecnológica, com limitada produção nacional, tornando-os inacessíveis para muitas instituições brasileiras.

O objetivo deste projeto é criar uma alternativa de baixo custo que simule ausculta cardíaca e respiratória para estudantes de Medicina Veterinária. O projeto consiste em um modelo anatômico realista associado a um aplicativo de configuração, oferecendo uma solução acessível que favorece a democratização do acesso a tecnologias educacionais e reduz o uso de animais vivos.

1.2 Escopo

O projeto abrange a criação de um modelo de boneco de animal inteligente, utilizando Internet of Things (IoT) e um aplicativo mobile. O objetivo principal é desenvolver um modelo que auxilie no aprendizado de ausculta cardíaca e pulmonar para alunos do curso superior de Medicina Veterinária.

O boneco permitirá que alunos simulem o processo de escuta de diferentes cenários em um modelo de pelúcia animal adaptado para aulas, sendo o mesmo, passível a configuração via smartphone dos docentes da instituição de ensino.

1.3 Objetivo Geral

- Adoção do simulador de baixo custo para o curso de medicina veterinária como elemento didático e complementar para o aprendizado.

1.4 Objetivos Específicos

- Integrar diferentes aplicações para a implementação do sistema.
- Desenvolvimento de aplicação IoT com comunicação com API e mobile.
- Prototipação de boneco animal com integração com IoT.
- Tratamento de som e reprodução com alta precisão em protótipo.
- Desenvolvimento de sistema seguindo práticas e recomendações de segurança.
- Desenvolvimento de aplicação mobile multiplataforma.

1.5 Partes Interessadas

Quadro 1 - Stakeholders

Stakeholder	Importância
Professores	Utilizam o sistema durante suas aulas para aprendizado de seus alunos.
Alunos	Utilizam o sistema para aprendizado e guias de aulas
Administrador	Utilizam o sistema para monitorar as ações realizadas e gerenciar os usuários
Equipe de Desenvolvimento	Equipe de desenvolvimento do sistema, responsável pela implementação e gestão do projeto.

Fonte: Autores do Projeto (2026)

1.6 Estrutura Analítica do Projeto (EAP)

1. Planejamento
 - 1.1. Documentação de Software
 - 1.2. Diagramas de Desenvolvimento
 - 1.2.1. Diagrama UML (Classe, Casos de Uso, Sequência).
 - 1.2.2. Sitemap (App e Web).
 - 1.2.3. Diagrama Entidade e Relacionamento.
 - 1.2.4. Diagrama Arquitetural.
 - 1.3. Interface e UI
 - 1.3.1. Prototipagem da Interface
 - 1.3.2. Documentação de UI/UX
 - 1.4. Cronograma de Entregáveis
 - 1.5. Plano de Recursos
 - 1.6. Orçamento do Projeto
 - 1.7. Termo de Uso e Privacidade
2. Desenvolvimento de Software (Servidor/App)
 - 2.1. Módulo de Usuários (Cadastro e Gestão)
 - 2.2. Sistema de Autenticação e Gestão de Credenciais
 - 2.3. Camada de Segurança e Criptografia
 - 2.4. Módulo de Auditoria.
 - 2.5. Termos de Proteção de Dados (LGPD)
 - 2.6. Módulo de Comunicação
 - 2.7. Módulo de Cenários Clínicos e Pagamento.
 - 2.8. Interface Gráfica (Aplicativo e Web)
3. Desenvolvimento IoT e Hardware
 - 3.1. Estrutura Física
 - 3.1.1. Diagramas Elétricos e Esquemáticos.
 - 3.1.2. Componentes Eletrônicos Soldados.
 - 3.1.3. Estrutura Física do Boneco.
 - 3.2. Software
 - 3.2.1. Camada de Comunicação em Rede
 - 3.2.2. Banco de Dados Local
 - 3.2.3. Camada de Segurança

3.2.4. Módulo de Reprodução de Sons

3.2.5. Módulo de Configuração de Cenários

4. Testes

4.1. Teste de Software

4.2. Teste de Usabilidade

4.3. Teste de Qualidade Sonora

4.4. Teste de Segurança

2 FLUXO DE CADASTRO

O sistema possui 3 perfis de usuários: Administrador, Aluno e Professor. Cada perfil possui fluxos específicos de autenticação e acesso, definidos de acordo com as funcionalidades disponíveis para cada tipo de usuário.

2.1 Administradores

No caso de administradores, o cadastro de novos administradores no sistema é realizado exclusivamente por administradores autenticados. Após acessar o painel administrativo, o administrador pode registrar um novo usuário com privilégios administrativos por meio de um formulário de cadastro disponibilizado pelo sistema.

Após o registro da conta, o novo administrador pode acessar o sistema realizando o processo de autenticação padrão, que consiste na validação das credenciais seguida da autenticação multifator (MFA). Somente após a validação do código de autenticação o acesso ao painel administrativo é concedido.

2.2 Professores

No caso de professores, o acesso ao sistema ocorre por meio do aplicativo mobile. O fluxo de autenticação inicia-se com a abertura do aplicativo, neste momento, o sistema verifica a existência de um token de autenticação armazenado na memória do dispositivo. Caso o token seja válido, o usuário é direcionado para tela inicial do sistema, sem necessidade de login.

Caso o token não seja válido, o usuário deve optar por realizar o login ou seu cadastro. No processo de login, após a validação de seu email e senha, é solicitado a etapa de autenticação multifator, onde o usuário deve informar o código de verificação que foi enviado ao seu email para concluir o acesso.

Para o processo de cadastro, o usuário deve preencher seus dados e realizar a validação do e-mail informado. Após a confirmação do e-mail, o cadastro é concluído e o usuário pode realizar a autenticação no sistema.

2.3 Alunos

No caso de alunos, o fluxo de abertura é semelhante ao fluxo do perfil professor. O processo inicia com a abertura do aplicativo, momento que o sistema verifica se existe token válido armazenado em sua memória. Caso o token seja válido, o usuário é redirecionado para a tela inicial do aplicativo.

Caso o token seja inválido, o usuário deve selecionar a opção login, sendo necessário informar seu email e senha para validação inicial. Logo após essa etapa, é solicitado a etapa de autenticação de multi fator adicional, na qual o usuário deve informar um código de verificação para concluir o acesso.

No processo de cadastro, o aluno deve solicitar ao seu professor responsável um pedido de cadastro na plataforma, e este deve informar os dados necessários para o cadastro do novo aluno pelo aplicativo.

3 REQUISITOS

Histórias do Usuário

Como administrador, quero que o sistema seja acessado apenas com email e senha já cadastrados.

Como administrador, quero que usuários sejam cadastrados usando nome, email, senha.

3.1 Servidor

3.1.1 Requisitos Funcionais

Gestão de Usuários

S-RF001 (Cadastro de Usuários) - O sistema deve permitir o cadastro de novos usuários mediante ao nome, email e senha.

S-RF002 (Alteração de Dados Cadastrais) - O sistema deve permitir os usuários alterarem os seus dados cadastrais

S-RF003 (Perfis de Usuários) - O sistema deve implementar os seguintes perfis de usuários:

- Alunos;
- Professores; e
- Administradores do Sistema.

S-RF004 (Recuperação de Senha) - O sistema deve permitir recuperação de senha mediante solicitação dos usuários.

S-RF005 (Consulta de Dados) - O sistema deve permitir aos usuários consultarem seus dados cadastrais, exceto pela senha do usuário.

S-RF006 (Exclusão da Conta) - O sistema deve permitir ao usuário excluir, mediante sua vontade, sua conta e seus dados mantidos na plataforma.

Autenticação

S-RF007 - (Login de Usuários) - O sistema deve permitir o login dos usuários mediante ao e-mail e senha.

S-RF008 (Segurança de Senhas) - O sistema deve utilizar algoritmo de hash seguro para criptografia, assim como adicionar salt as senhas criptografadas.

S-RF009 (Autenticação Via Token) - O sistema deve implementar autenticação de usuários via Token.

S-RF010 (Política de Senha) - O sistema deve implementar política de criação de senha segura, exigindo no mínimo 8 caracteres, incluindo letras maiúsculas, minúsculas, números e caracteres especiais.

S-RF011 (Notificação de Login) - O sistema deve informar ao usuário, mediante a notificação de e-mail, sempre que houver o login em um novo dispositivo.

S-RF012 (Logout do Usuário) - O sistema deve permitir os usuários encerrarem sua sessão quando desejarem.

Segurança

S-RF013 (Bloqueio de Rotas do Servidor) - O sistema deve implementar bloqueio de rotas para usuários não autenticados, permitindo o acesso apenas aos usuários que possuírem autenticação e papel especificado pela rota.

S-RF014 (Multifator) - O sistema deve implementar mecanismo de geração e validação de código multi-fator, notificando o usuário via email cadastrado.

S-RF015 (Criptografia dos Dados Bancários) - O sistema deve manter em seus bancos dados, os dados relacionados aos dados bancários do usuário, criptografados com algoritmo seguro.

Auditoria

S-RF016 (Logs do Servidor) - O sistema deve implementar auditoria de ações via Logs do sistema. As ações auditadas serão:

- Alteração dos dados cadastrais.
- Pedidos, falhas e sucesso na recuperação de senha.
- Login e Logout do sistema.

Termos de Proteção de Dados

S-RF017 (Termo de Uso e Privacidades de Dados) - O sistema deve permitir os usuários lerem e consentirem ou não com os termos de uso do aplicativo. Permitindo também revogar a qualquer momento.

S-RF018 (Política de Propriedade dos Dados) - O sistema deve permitir a consulta, exportação e exclusão dos dados do titular.

Comunicação

S-RF020 (Restrição de Requests) - O sistema de autenticação deve processar apenas as requisições de autenticação enviadas pelo aplicativo e futuros sistemas parceiros.

S-RF021 (Conexão com Dispositivos) - O sistema deve receber e enviar dados e configurações aos dispositivos conectados a ele.

Cenários Clínicos

S-RF022 (Vinculação de Dispositivos) - O sistema deve permitir aos professores vincular dispositivos a suas contas.

S-RF023 (Obter Cenários Clínicos) - O sistema deve permitir obter cenários clínicos de diferentes animais para uso no dispositivo, mediante a compra dos mesmos.

S-RF024 (Configurar Dispositivos) - O sistema deve permitir alterar os cenários clínicos ativos no dispositivo.

S-RF025 (Pagamento de Cenários) - O sistema deve processar o pagamento de cenários clínicos mediante aos dados bancários do usuário.

3.1.2 Requisitos de Dados

S-RD001 (Criptografia dos Banco de Dados) - O sistema deve armazenar os dados sensíveis dos usuários de forma criptografada.

S-RD002 (Token Revogados) - O sistema deve armazenar a lista de tokens revogados enquanto ainda não expiraram.

S-RD003 (Requisições Multi-fator) - O sistema deve armazenar, em um banco em memória, a requisição inicial das funcionalidades com multi-fator, para serem processadas após validação do código. Os valores devem ser indexados via UUID do usuário.

3.1.3 Requisitos Não Funcionais

S-RNF001 (Criptografia das Senhas) - As senhas devem ser criptografadas usando algoritmo BCrypt para manter a confiabilidade do sistema.

S-RNF002 (Salt de Senha) - O salt adicionado as senhas deve ser único para cada usuário do sistema.

S-RNF003 (Obrigatoriedade de 2FA) - O multi-fator é obrigatório para segurança do sistema, deve ser implementado nas seguintes funcionalidades:

- Registro: Logo após o registro para validar o e-mail cadastrado.
- Autenticação: Após autenticação primária do usuário.
- Alteração e reset de senhas: Tanto para alteração quanto para o reset de senhas, o usuário deve informar o código recebido.
- Alteração dos dados: Para validação dos dados e caso o email seja alterado, também deve ser validado.

S-RNF004 (Limite de Tentativas) - Cada usuário deve ter total de 5 tentativas falhas consecutivas de login.

S-RNF005 (Segurança de Tokens) - O token de autenticação deve utilizar da tecnologia JWT, e serem transmitidos criptografados.

S-RNF006 (Tempo de Expiração de Token) - O token de autenticação deve ter tempo de expiração de 2h.

S-RNF007 (Invalidação de Token de Recuperação) - O token de recuperação de senha deve ser invalidado após o uso.

S-RNF008 (Mascaramento de Logs) - Os Logs do sistema devem mascarar dados sensíveis e não mantê-los em texto claro.

S-RNF009 (Comunicação Criptografada) - A comunicação do sistema na rede deve ser feita de forma segura usando o protocolo TLS/HTTPS.

S-RNF010 (Termo de Uso) - O usuário só poderá continuar o processo de cadastro, após ter consentido os termos de privacidade e coleta de dados.

S-RNF011 (Proteção de Logs) - Os Logs do sistema devem ser armazenados em um banco append-only para evitar alteração dos Logs.

S-RNF012 (Limite de entradas de formulário) – Os campos de entrada do usuário devem limitar seu tipo e tamanho, conforme necessário, para evitar a inserção de comandos por meio de seus campos.

3.1.4 Regras de Negócio

S-RN001 - Caso o usuário tenha 5 tentativas falhas de login ou mais, o sistema deve bloqueá-lo por período de 1h.

S-RN002 - Ao ser autenticado, o usuário deve validar a autenticação de dois fatores para continuar no sistema.

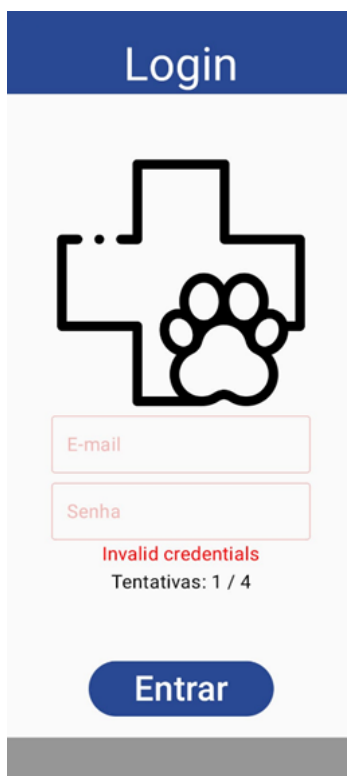
S-RN003 - Sempre que o usuário realizar uma alteração em seus dados, o sistema deve registrar um log do ocorrido, salvando a data, hora, usuário, operação e o que foi alterado, dados sensíveis devem ser mascarados.

S-RN004 - Toda comunicação em rede feita pelo sistema, deve utilizar de métodos seguros de comunicação, por meio do protocolo TLS/HTTPS.

4.2 Proteção contra ataques de Brute Force

O endpoint de autenticação implementa um mecanismo que limita as tentativas de login. Sendo permitidos 5 tentativas consecutivas de autenticação mal-sucedidas, a conta do usuário é bloqueada temporariamente por 15 minutos, permitindo novas tentativas após esse período.

Figura 2 - Invalidação de Sessão

A screenshot of a mobile application login screen. At the top is a blue header with the word "Login" in white. Below the header is a large black outline of a cross with a paw print in the center. Underneath the icon are two input fields: "E-mail" and "Senha". Below these fields, the text "Invalid credentials" is displayed in red, followed by "Tentativas: 1 / 4" in black. At the bottom of the form is a blue button with the word "Entrar" in white. The entire form is set against a light gray background.

Fonte: Autores do Projeto (2026)

Além da verificação aplicada ao processo de login, utilizou-se a biblioteca Bucket4J para bloqueio de requisições baseado no IP do cliente, evitando que atacantes possam descobrir usuários existentes no sistema.

4.4 Autenticação Multifator (MFA)

O sistema implementa um segundo fator de autenticação baseado em código de verificação de uso único. Após a validação inicial das credenciais, um código temporário é gerado e enviado para o usuário via e-mail cadastrado. O acesso a API é concedido após a validação deste código adicional.

Figura 4 - Tela de Validação Código MFA



Fonte: Autores do Projeto (2026)

4.5 Redefinição e Alteração de Senha

O sistema disponibiliza dois fluxos distintos para atualização de senha. Na alteração de senha, o usuário autenticado deve informar sua senha atual e a nova senha desejada. O sistema valida a senha atual antes de aplicar a alteração, garantindo que apenas o titular da conta possa realizar a operação.

Para a redefinição de senha, utilizada quando o usuário não possui acesso à conta, o sistema adota um fluxo seguro baseado em token de uso único. Ao solicitar a redefinição, um token temporário é gerado e enviado para o e-mail cadastrado do usuário. Esse token possui tempo de expiração definido e é invalidado imediatamente após ser utilizado, impedindo a reutilização. A nova senha só é persistida após a validação bem-sucedida do token, e o hash é calculado pelo BCrypt antes do armazenamento.

4.6 Logs de Auditoria

O sistema registra eventos relevantes de segurança e acesso por meio de logs de auditoria, permitindo rastreabilidade das ações realizadas. São registrados eventos como: autenticações bem-sucedidas e mal-sucedidas, emissão tokens JWT, validações de MFA, além de alterações e redefinições de senha.

Cada registro de log contém informações como identificador do usuário, tipo do evento, endereço IP de origem, data e hora da ocorrência. Esses registros são armazenados de forma estruturada e podem ser utilizados para monitoramento, detecção de comportamentos suspeitos e resposta a incidentes de segurança.

Figura 5 - Logs do Sistema

	id	AZ action	AZ details	AZ entity	AZ ip	AZ status	timestamp
80	Í ¤WLx xðìð-Y [16]	Login Bem Sucedido	[NULL]	LOGIN	0:0:0:0:0:0:1	SUCCESS	2026-04-05 22:45:12.629953
81	IA T GÇ=E +ó%Øk [16]	Login Bem Sucedido	[NULL]	LOGIN	0:0:0:0:0:0:1	SUCCESS	2026-04-05 22:44:16.234841
82	Ö EjYM ÜÇYËÜ [16]	Envio das credenciais para login	E-mail ou senha inválidos	LOGIN	0:0:0:0:0:0:1	FAILED	2026-04-04 17:32:45.735400
83	ãl± **N' Boð]p : [16]	Envio das credenciais para login	E-mail ou senha inválidos	LOGIN	0:0:0:0:0:0:1	FAILED	2026-04-04 19:21:02.379260
84	ã5 2 ØH ú+/?~ [16]	Login Bem Sucedido	[NULL]	LOGIN	0:0:0:0:0:0:1	SUCCESS	2026-04-05 00:34:22.988312
85	æäl?=- Jö~> <h6P [16]	Envio das credenciais para login	E-mail ou senha inválidos	LOGIN	0:0:0:0:0:0:1	FAILED	2026-04-04 17:24:31.233600
86	ég)4 J< T ¥0É [16]	Registro do usuário	[NULL]	REGISTER	192.168.15.99	SUCCESS	2026-04-05 14:08:35.863293
87	ê(T O@Ü yUÖÐ@a [16]	Registro do usuário	[NULL]	REGISTER	0:0:0:0:0:0:1	SUCCESS	2026-04-04 16:52:44.311852
88	ðÇ T Cÿª Cw R0# [16]	Envio das credenciais para login	E-mail ou senha inválidos	LOGIN	0:0:0:0:0:0:1	FAILED	2026-04-04 16:59:14.161701
89	òlyÄ HZ o*!e ' [16]	Envio das credenciais para login	[NULL]	LOGIN	0:0:0:0:0:0:1	SUCCESS	2026-04-05 22:43:31.565488
90	ö lþA.O9@k ¼-Ö« [16]	Envio das credenciais para login	E-mail ou senha inválidos	LOGIN	0:0:0:0:0:0:1	FAILED	2026-04-04 16:55:19.095518
91	ùèLÖ @C Ö #uÖª [16]	Logout do usuário	[NULL]	LOGOUT	192.168.15.99	SUCCESS	2026-04-05 14:02:01.538870
92	ùæXë Äi Y jÖ(« [16]	Solicitação de Redefinição de Senha	[NULL]	PASSWORD	192.168.15.99	SUCCESS	2026-04-05 14:06:26.587435
93	ü u æDË;-ÿ=çðDÜ [16]	Envio das credenciais para login	E-mail ou senha inválidos	LOGIN	0:0:0:0:0:0:1	FAILED	2026-04-04 17:49:06.999198
94	ü æ)äH. c y'E T [16]	Envio das credenciais para login	E-mail ou senha inválidos	LOGIN	0:0:0:0:0:0:1	FAILED	2026-04-04 16:52:58.272427
95	yq i½Nª óbd[Ä- [16]	Envio das credenciais para login	[NULL]	LOGIN	0:0:0:0:0:0:1	SUCCESS	2026-04-05 22:46:16.822558
96	þ tY'C]Ä¼5 Ür X [16]	Logout do usuário	[NULL]	LOGOUT	192.168.15.99	SUCCESS	2026-04-05 13:44:53.161608
97	ÿÖ« B-¹TxG A [16]	Redefinição de Senha	[NULL]	PASSWORD	192.168.15.99	SUCCESS	2026-04-05 14:09:46.759348

Fonte: Autores do Projeto (2026)

4.7 Criptografia de Token

O aplicativo mantém salvo o token de autenticação, proveniente do processo de login, em seu armazenamento interno para reuso em requisições futuras a API.

A implementação utiliza a biblioteca Jetpack DataStore, devido a descontinuidade da antiga biblioteca SharedPreferences. O DataStore não provê criptografia nativa para os dados de preferências armazenados, devido a isso, foi necessário a implementação adicional com Android Keystore System. Esse sistema permite emitir e armazenar as chaves criptográficas do sistema de forma segura. A configuração de criptografia seguiu os seguintes parâmetros:

- Algoritmo: AES (*Advanced Encryption Standard*)
- Modo de Operação: CBC (*Cipher Block Chaining*)
- Preenchimento: PKCS7

- Gerenciamento de Chaves: Armazenamento em ambiente de execução confiável (TEE) gerenciado pelo sistema operacional.

Figura 6 - Implementação da Criptografia Android

```

1  public fun encrypt(text: String): String {
2      // Inicialização do objeto com a configuração de criptografia
3      val cipher = Cipher.getInstance(TRANSFORMATION)
4
5      // Inicialização do objeto para criptografar dados
6      cipher.init(Cipher.ENCRYPT_MODE, getKey())
7
8      // Definição do Valor de Inicialização
9      val iv = cipher.iv
10
11     // Dados Criptografados
12     val encryptedBytes = cipher.doFinal(text.toByteArray(Charsets.UTF_8))
13
14     // Transformação dos dados binários em valor textual
15     val encrypted = Base64.encodeToString(iv + encryptedBytes, Base64.NO_WRAP)
16     return encrypted
17 }
18
19 public fun decrypted(data: String): String {
20     // Decodificador do valor textual
21     val decoded = Base64.decode(data, Base64.NO_WRAP)
22
23     // Inicialização do objeto com a configuração de descripografia
24     val cipher = Cipher.getInstance(TRANSFORMATION)
25
26     // Particionando os valores da cifra
27     val iv = decoded.copyOfRange(0, cipher.blockSize)
28     val encryptedBytes = decoded.copyOfRange(cipher.blockSize, decoded.size)
29
30     // Inicialização do objeto para descripografar dados
31     cipher.init(Cipher.DECRYPT_MODE, getKey(), IvParameterSpec(iv))
32
33     // Bytes descripografados
34     val decryptedBytes = cipher.doFinal(encryptedBytes)
35
36     // Transformação dos bytes em valor textual
37     val decrypted = String(decryptedBytes, Charsets.UTF_8)
38     return decrypted
39 }

```

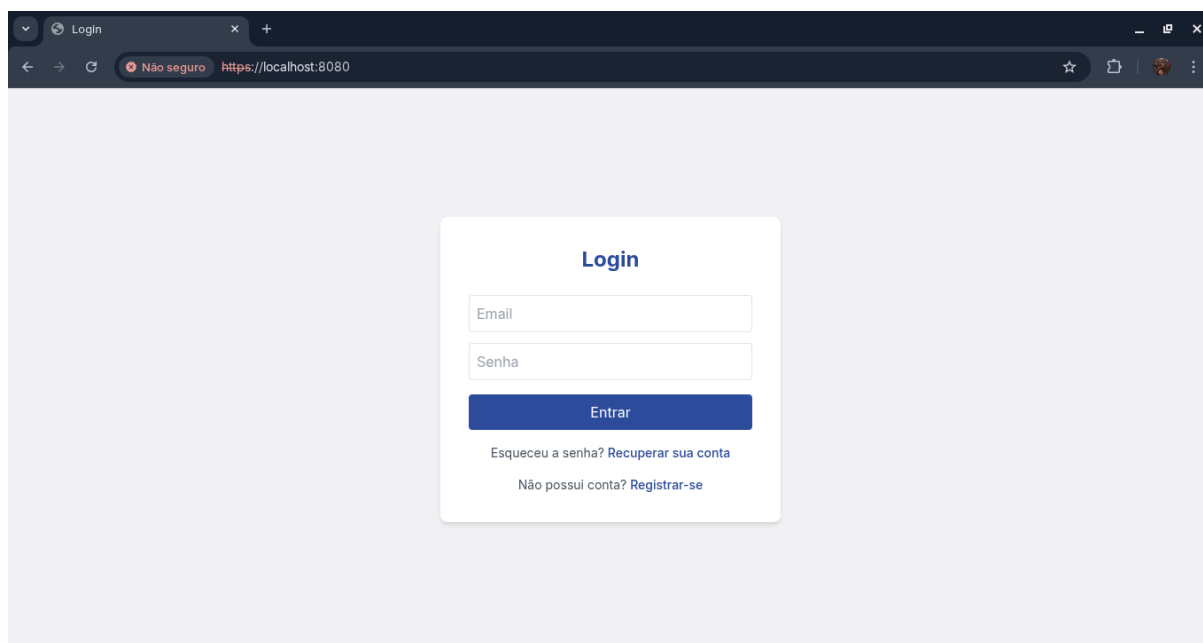
Fonte: Autores do Projeto (2026)

4.8 Criptografia e Comunicação Segura

A comunicação entre o cliente e o servidor é realizada exclusivamente por meio do protocolo HTTPS sobre TLS. O servidor está configurado para rejeitar automaticamente requisições via HTTP, impedindo a transmissão de dados em texto plano e garantindo a integridade das informações em trânsito.

Para assegurar a autenticidade e prevenir ataques, a API utiliza certificados digitais válidos e o protocolo TLS. Além do sistema implementar a política HSTS, que força o uso de conexões seguras em todas as interações. Esse mecanismo garante que credenciais, tokens JWT e dados dos usuários trafegam de forma criptografada entre as pontas.

Figura 7 - Uso do protocolo HTTPS



Fonte: Autores do Projeto

5 NIST Framework

No servidor, são considerados ativos:

Ativo	Descrição	Responsabilidade
Banco de dados	Responsável pelo armazenamento das informações dos usuários.	• Dados cadastrais e credenciais. • Tokens de autenticação e multifator. • Logs de auditoria.
Serviços da API	Responsável pelo processamento das requisições	• Mecanismos de autenticação e gerenciamento de sessão. • Mecanismo de emissão, validação e invalidação de tokens. • Mecanismo de autenticação e multifator. • Mecanismo de recuperação de senha.
Infraestrutura	Responsável pelo funcionamento da aplicação	• Servidor • Enlace de Conexão • Banco de Dados • Roteadores e Firewalls • Ambiente

Na aplicação mobile, são considerados ativos:

Ativo	Descrição	Responsabilidade
Interface do Sistema	Responsável pela apresentação dos dados.	• Exposição dos dados ao usuário.
Armazenamento	Responsável pelos dados salvos localmente.	• Mecanismo de armazenamento de token.
Dispositivo	Responsável pela execução e armazenamento da aplicação	• Armazenamento dos dados do cliente. • Execução da aplicação. • Restrição de acesso ao aplicativo.

No dispositivo embarcado, são considerados ativos:

Ativo	Descrição	Responsabilidade
Software	Responsável pelo funcionamento do dispositivo	• Mecanismo de reprodução. • Mecanismo de comunicação. • Mecanismo de armazenamento. • Mecanismo de segurança.
Memória	Responsável pelos dados salvos localmente.	• Armazenamento de cenários. • Armazenamento do software.
Dispositivo	Responsável pela execução e armazenamento da aplicação	• Armazenamento dos dados do cliente. • Execução da aplicação. • Restrição de acesso ao aplicativo.

Ativos adicionais:

Ativo	Descrição	Responsabilidade
Comunicação	Responsável pelo transporte de dados entre as partes.	• Requisições. • Arquivos e dados.